TECHNICAL REPORT · FINAL SUBMISSION

Personal AI Dashboard with Evidence-Grounded Analytics

Architecture, AI-assisted engineering method, verification evidence and lessons learned

Author	Dor Meir
Report date	18 October 2026
Evidence basis	`main` at application release `32d849a` (B-05, B-07, B-13 and B-15 integrated on top of B-14 `f06e00d`), with the integration Verifier's recorded results
Final release SHA	**`32d849a`** (application release on `main`; later commits change only documentation and two Windows test fixes)
Built with	Claude Code: Architect → Coder → independent Verifier, under an Integration Lead, with explicit Owner approval gates

Evidence convention used throughout. TESTED a command or browser flow was executed and its result recorded · REVIEWED checked by reading, no automated run · DESIGNED approved design, not yet implemented or not yet merged · NOT RUN explicitly not exercised. Every number in this report comes from the development record (`PROJECT_PLAN.md`, `DEVELOPMENT_LOG.md`, `docs/analytics/worker-notes.md`, commit messages, or a command run by the submission session and cited in §11). The planning, log and audit files cited here are kept in the private development repository and are not part of this public snapshot.

Contents

1. Executive summary
2. Problem and intended experience
3. Initial approach and product adaptation
4. MVP scope and deferred capabilities
5. System architecture
6. Analytics architecture
7. AI-assisted engineering method
8. Prompts, iterations and decisions
9. Defects found by independent verification
10. Testing strategy
11. Verification results
12. Synthetic dataset and evaluation
13. Privacy, security, reproducibility, deployment
14. Reflection, limitations, future work
15. Final implementation status (integration)

Appendix A. Decision register

1. Executive summary

The Personal AI Dashboard is a local, private web application for analyzing one's own life: food and health, content consumption, job applications and tasks. It provides deterministic history, statistics and charts, and an **Analyst** that answers natural-language questions with answers grounded in the user's records. A runtime OpenAI agent may only call six read-only, user-scoped tools; it never writes SQL and never writes numbers. Every value shown is computed by the backend, and every claim passes a deterministic **Evidence Validation** layer (rules V1–V14) before display. When the data cannot support an answer, the product says so in a fixed, Owner-specified message.

A **Demo Mode** with an entirely synthetic 30-day dataset lets any reviewer install and explore the product with no Google account and no API key.

Objective	Outcome at the evidence date
Reliable personal record keeping	**TESTED** 11 record domains with manual create / edit / soft delete / restore / confirmed permanent delete; database-enforced uniqueness; data-preservation guards (B-04, F-01).
Reproducible reviewer experience	**TESTED** Demo Mode: checksum-locked fixture, fresh working copy, local-only isolation (B-14, Verifier PASS).
Grounded AI analytics	**TESTED** Tools, evidence ledger and validator V1–V14 (B-13, Verifier FAIL → FAIL → PASS) and the agent loop with the Analyst UI (B-15), integrated in `32d849a` and checked by the integration Verifier with a scripted model on the demo data. The offline golden set and live OpenAI runs were not executed.
Deterministic dashboard metrics and charts	**TESTED** B-05 metric registry (independent calculator, 119,256 randomized checks with 0 mismatches) and B-07 dashboard (Playwright at 1440×900 and 390×844), integrated in `32d849a`.
Disciplined AI-assisted engineering	**TESTED** Every implementation checkpoint closed by an independent Verifier PASS; 30+ real defects caught before commit (§9).

2. Problem definition and intended user experience

People who log their sleep, meals, workouts, reading or job search usually end up with scattered records and no trustworthy way to ask "what actually changed?". General chat assistants can produce fluent answers, but they will happily invent numbers, ignore gaps in the data, and imply causation. The product goal is the opposite: **a personal analyst that is only allowed to say what the records support**.

Intended experience

- **Record** daily activities quickly through accessible forms on desktop or phone; duplicates are rejected with a clear message.
- **Review** a 15-day history per domain where an undocumented day shows "No record entered for this day" (in Hebrew in the UI) and is never treated as a zero; every value shows its actual record date.
- **See trends** in aggregates whose denominators are documented days only (e.g. 7 workouts on 5 documented days = 1.4 per day).
- **Ask** a free-form question ("Did my sleep improve in the second half of the month?") and get either a validated answer with coverage lines and evidence, a partial answer that names what is missing, or an honest "not enough data".

Domain rules that shape everything else

Rule	Why it matters for AI
Missing ≠ zero; denominators = documented days	The agent cannot turn "forgot to log" into "did nothing".
Database uniqueness is authoritative; no automatic overwrite	No model output can ever replace a stored record.
All retrieval and arithmetic is fixed, parameterized SQL	No model-generated SQL; user scoping cannot be bypassed by prompt text.

3. Initial architectural approach and iterative product adaptation

The project ran in two controlled stages (§7). In **Phase A** (16 Oct 2026, 13:47–14:23) the Architect proposed one bounded decision at a time and the Owner approved, amended or corrected each: MVP scope (A-01), stack (A-02), schema (A-03), AI sources and auth (A-04), UI and test matrix (A-05), then **GATE-A** authorized implementation.

The original scope included *external* intelligence: a job-recommendation agent and an industry-trend agent using OpenAI web search, triggered by a "Run now" button (max 3/day), plus AI free-text intake with a clarification loop.



Each step recorded verbatim; superseded text kept and marked, never deleted.

Figure 1. Requirements refinement timeline.

Adaptation 1 — focus on the user's own data (ADR-005)

After the foundation was in place, the Owner issued a directive (recorded verbatim in `owner-directive-2026-10-17-personal-ai-analytics.md`) to concentrate the product on analyzing the user's own life, activities, habits and trends. The directive states that this is a deliberate conceptual shift and not a token, cost or time decision. External job discovery, recommendations and trend retrieval moved out of the MVP (tables kept, no UI); a single grounded analytics agent, Evidence Validation and Demo Mode moved in. The change was handled as a **planning-only session**: the Architect wrote ADR-005 with a supersession table and twelve open decisions (O-0…O-12), Main Claude corrected one Architect claim against git history (LOG-016), and nothing was implemented until the Owner approved the decisions (LOG-017).

Adaptation 2 — concentrate runtime AI on analytics (LOG-019)

The Owner then deferred AI free-text intake (B-06): "Manual data entry from B-04 is sufficient for this submission," so that the product's runtime AI is concentrated on personal analytics and evidence-grounded insights. The same directive set the dataset to about 30 fictional days and introduced a controlled parallel workstream for analytics (§7.3).

Both adaptations narrowed the surface where an LLM can be wrong, and moved it to the place where the backend can check it.

4. Final MVP scope and intentionally deferred capabilities

In the MVP	Deferred (history and tables kept)
• Manual records for 11 domains, soft delete, Recently deleted, restore, confirmed permanent delete • 15-day history with record dates and undocumented-day placeholders • Deterministic aggregates and server-rendered SVG charts (B-05, B-07) • Analyst: one function-calling agent, six read-only tools, Evidence Validation (B-13, B-15) • Demo Mode with synthetic fixture; Google sign-in for personal mode • Responsive desktop and mobile UI (top tabs / bottom bar)	• B-06 AI free-text intake, clarification agent, AI calorie estimates • B-08 job recommendations; B-09 industry trends; "Run now"; CV profile • Scheduler; persisted analysis history; multi-turn analyst conversations • Embeddings, vector DB, multi-agent frameworks, LLM-generated SQL (rejected by design) • B-11 temporary Cloudflare tunnel check (optional)

5. System architecture

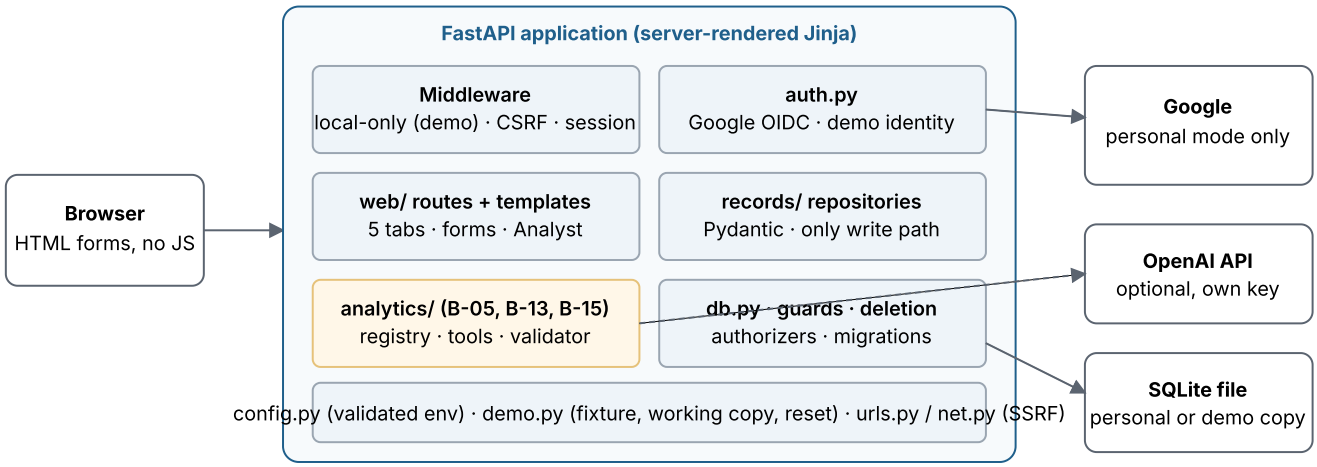


Figure 2. Component view. Amber = analytics package (partly on a feature branch at the evidence date).

Concern	Decision and rationale	Evidence
Stack	Python FastAPI + Jinja/HTMX + SQLite (A-02 option A, chosen over TypeScript/React and Next.js/Prisma): smallest dependency budget, no JS build step, one process to start and stop.	LOG-003
Data model	17 STRICT tables + `daily_calories` view; user-scoped canonical-key UNIQUE constraints; composite FKs; append-only `meal_calorie_estimates` (an Owner correction, LOG-005).	B-03, LOG-004/005
Data preservation (ADR-004)	RESTRICT FKs; deletes only through grant-guarded `app/deletion.py`; `REPLACE` / `UPSERT` neutralized by triggers and an authorizer; immutable identity; migration invariants checked before COMMIT; app connections cannot run DDL.	F-01, LOG-011/012
Soft delete	Migration 002 adds `deleted_at`; Recently deleted, restore, and a separately confirmed permanent delete (O-1).	B-04
Authentication	Google OIDC via Authlib (state, nonce, PKCE); allowlist binds the stable `google_sub`; signed 8 h cookie; CSRF middleware; a test login accepted only from a loopback peer.	B-02, LOG-013/014
Demo Mode	`APP_MODE=demo`: localhost only, refuses tunnel/https URLs and `TEST_AUTH`; content-based mode exclusivity (demo marker in SQLite `application_id`); per-mode cookie and signing key; outermost local-only middleware; fresh working copy from a SHA-256-verified JSON fixture.	B-14, LOG-020
Deployment	Local process started and stopped by `scripts/start.ps1` / `stop.ps1`; optional Cloudflare quick tunnel in personal mode only. No permanently hosted server.	A-04 D2, B-01

6. Analytics architecture

The analytics design (ADR-005 §3–§5) separates **what the model decides** (which tools to call, how to phrase findings) from **what the backend guarantees** (every number, coverage, direction and caveat).

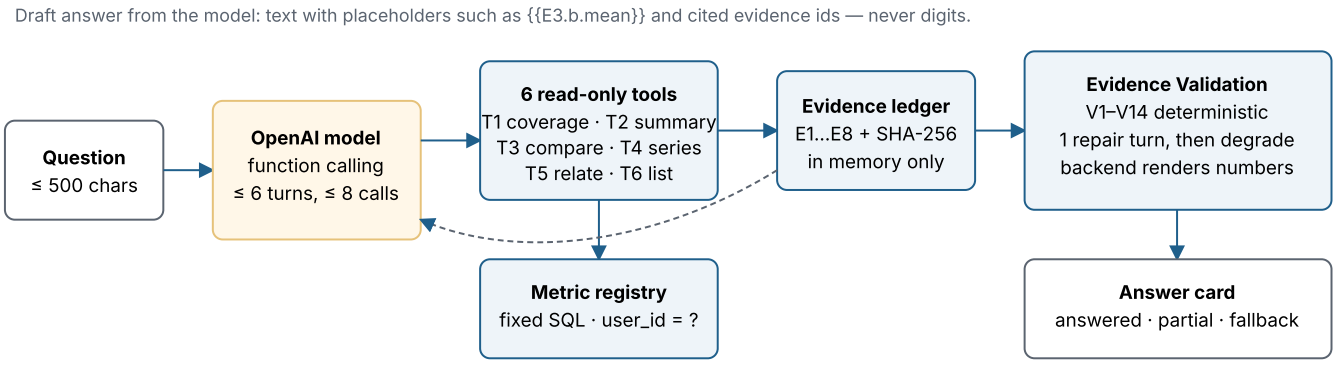


Figure 3. Request flow of the Analyst (ADR-005 §3.1). The dashed arrow returns tool results to the model as data envelopes.

6.1 Metric registry and read-only tools

- **Closed registry** (B-05, shared with the dashboard): e.g. `sleep.hours`, `steps.count`, `weight.kg`, `workouts.count`, `tasks.completion_rate`, `job_applications.progress_rate`, each with kind, unit and `min_delta`.
- **Six tools** with strict Pydantic argument models (`extra="forbid"`, so no `user_id` can be passed). `user_id` comes only from the server-built `ToolContext`.
- **Fixed SQL only**: module-level constant queries chosen by enum; values bound with `?`; a static test bans string-formatted SQL in `app/analytics/`.
- **Hardened read-only connection**: `PRAGMA query_only`, a deny-by-default authorizer, a 2 s statement budget, row caps, and 8 KB result trimming.

6.2 Evidence ledger and placeholder rendering

Each successful tool call becomes an evidence item (`E1` … `E8`) with normalized arguments and a SHA-256 of its result. The model writes prose such as "Average sleep was {{E3.b.mean}} in the second half" and cites `E3`. The backend replaces placeholders with formatted values (hours to 1 dp, steps with separators, signed deltas, DD.MM.YYYY dates), appends a coverage line ("Based on N documented days of M") and, for relationships, the caveat "Association only; this does not show cause." Text stored by the user (`untrusted_text`) can never be addressed by a placeholder.

6.3 Deterministic validation (V1–V14)

Rule	Requirement	Check (default thresholds)
V1–V2	Well-formed, supported	Strict schema; every finding cites existing evidence; every placeholder resolves to an allowed leaf of cited evidence.
V3	No free numbers	No digit or English number word outside placeholders.
V4–V5	Data exists, enough of it	Value ≥ 3 observations; trend ≥ 7 points over ≥ 14 days at ≥ 50 % coverage; correlation ≥ 10 pairs; groups ≥ 5 days.
V6–V7	Missing days, comparable periods	Coverage line always shown; absolute words and "skipped/missed" claims rejected when coverage < 1; comparisons need ≥ 3 documented days and coverage ≥ 0.4 per period.
V8–V9	Values and direction correct	Derived fields recomputed (tolerance 1e-9); declared direction must match the backend sign; below `min_delta` it must be "no clear change".
V10	No causation	Rejects causal and predictive language ("because", "leads to", "improves", "will", …).
V11–V14	Consistency and safety	Finding kind matches tool; no URLs or markup; status consistent; charts only from compatible evidence.

If validation fails, the model gets **one** repair turn containing only error codes. If it still fails, invalid findings are dropped (status becomes *partial*) or, if none remain, the Owner's fallback is shown: "*The available records do not provide sufficient reliable information to analyze {topic} for the selected period. You can add relevant records or expand the date range and try again.*" Unvalidated model text is never displayed.

6.4 OpenAI integration

Designed (B-15): Responses API with function calling via an injected `ModelClient` port, `store=false`, 30 s per call and 75 s per question, a per-question token budget (default 40,000) and an hourly cap (default 20, one in flight), privacy-safe logging (never the question, results or output). Tests replace the client with scripted models. **NOT RUN** No live OpenAI call has been made; live evaluation requires the Owner's O-9 approval.

7. AI-assisted software-engineering methodology

7.1 Roles

Role	Responsibility	Constraint
Owner (human)	Product direction, approvals, corrections, external setup.	Approval never inferred from silence.
Architect (Claude agent)	One bounded design decision at a time with options and tradeoffs.	Read-only tools (Read, Grep, Glob).
Coder (Claude agent)	Implements one approved task with focused tests.	Never self-certifies.
Verifier (Claude agent)	Independently runs tests, black-box probes and Playwright at 1440×900 and 390×844; reports PASS / FAIL.	Read-only on the code; cannot fix what it finds.
Integration Lead (main Claude session)	Orchestrates tasks, owns planning documents, sole writer to `main`, runs the integration Verifier after merges.	Material changes go back to the Owner.

The build-time Claude agents are distinct from the *runtime* OpenAI agent inside the product.

7.2 Workflow

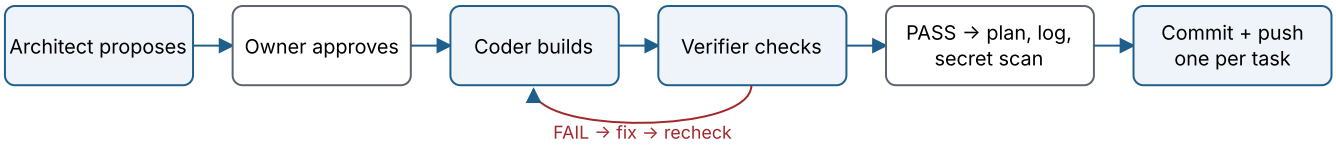


Figure 4. Phase B loop. A task is *Done* only with recorded passing evidence.

Source-of-truth discipline: `PROJECT_PLAN.md` holds task state and acceptance criteria; `DEVELOPMENT_LOG.md` holds prompts, decisions, defects and evidence; `RESUME_CHECKPOINT.md` lets a new session resume without conversational memory (used at LOG-010 and LOG-017).

7.3 Parallel and delegated development

From LOG-019 the work ran in three isolated checkouts with a written protocol (`parallel-work-and-metrics-contract.md`):

Workstream	Scope	Branch	Coordination rule
Main / Integration Lead	B-14 → B-05 → B-07 → integration	`main`	Only writer to `main` and planning docs
Analytics worker	B-13 → B-15	`feature/analytics-agent`	Builds T1–T5 against a **frozen B-05 metrics contract** through `ports.py` and an in-memory fake, until B-05 merges
Submission worker	Report, README draft, audit, release, video plan	`feature/submission`	Documentation only; uses committed evidence only

File ownership is exclusive per workstream. The frozen interface let analytics proceed in parallel without waiting for the registry implementation; its cost is that tools are verified against a fake until integration (§15).

8. Significant prompts, iterations, discoveries and decisions

Record	Prompt or decision (quoted where recorded verbatim)	Effect
LOG-002	"Start Phase A with the Architect agent only. Propose the first architecture decision with alternatives and tradeoffs. Wait for my explicit approval before proceeding."	Established the one-decision-at-a-time design loop.
LOG-005	Owner corrected the Architect's framing of LLM calorie re-estimation as an exception to "AI never overwrites".	Append-only `meal_calorie_estimates` + `daily_calories` view, before any code existed.
LOG-007	"approve A-05, start Phase B"	GATE-A passed.
LOG-011	Data-integrity directive: "Data Integrity and Deletion Policy — Highest Priority ..."	F-01 inserted before sign-in; ADR-004.
LOG-013	Owner required the project to remain company-neutral and asked that a company reference be removed from the log while keeping the history intact.	Neutrality requirement; drives the fresh public repository (§13).
LOG-015	Product direction change to personal analytics (verbatim file).	ADR-005; planning-only session.
LOG-016	Main Claude checked an Architect claim (that commit metadata contained the Owner's email) against git history and found it false.	Rationale for the public-repo approach rewritten on facts.
LOG-017	Owner approved O-0...O-8, O-10...O-12; live paid calls (O-9) still need approval.	Autonomous execution within the approved architecture.
LOG-019	"B-06 ... is now Deferred / Out of MVP. Manual data entry from B-04 is sufficient for this submission."	Runtime AI concentrated on analytics; 30-day fixture; parallel workstreams.
Worker notes D-3	Analytics worker flagged that weight logged ~2×/week can never meet the generic 50 % trend-coverage floor, and applied the weight-specific V5 rule instead.	Recorded as an interpretation for Owner approval; no threshold changed silently.

9. Representative failures detected by independent verification

The Coder's own test suite was green before every one of these rounds. Each defect was found by the independent Verifier (or by the Owner, for design errors), fixed, and rechecked.

Task / round	Defect	Root cause	Correction
B-01 R1	Quick-tunnel start could not set the public URL without a restart; a test login could pass its localhost guard while publicly exposed (High).	Start order assumed the URL was known in advance.	Tunnel-first start; public URL taken from the tunnel.
B-01 R1	Configuration errors echoed secret values; the example placeholder secret validated.	Default pydantic error messages; length-only check.	Value-free `SettingsError`; placeholder and low-entropy secrets rejected.
B-03 R1	Canonical-key separator `|` allowed collisions; migration COMMIT inside a file broke atomicity.	Separator present in user text; runner trusted file content.	`\x1f` separator; runner rejects transaction statements.
F-01 R1–R5	Five consecutive bypasses of the data-preservation guards, e.g. `;COMMIT;` inside a migration, `UPDATE … SET rowid=77`, a `WHEN 0` guard, a double-quoted WHEN clause read by SQLite as a string constant, a migration inserting standing deletion grants.	Guards were verified by **matching trigger text**, which an adversary can mimic.	SQLite authorizers (no DDL from the app, no transaction control in migrations), exact guard templates, invariants before COMMIT and at startup. R6 PASS: 28 earlier repros rejected.
B-02 R1	Test login trusted the client-supplied `Host` header: a remote request with `Host: localhost` got a session.	"Local" decided from a header, not the peer.	Also require a loopback peer address; more proxy headers refused. Five new tests failed on the pre-fix code.
B-02 R2	A client disconnect mid-form let CSRF middleware pass a truncated body as complete (raw-socket repro).	Body replay did not track completeness.	Partial bodies dropped; R3 PASS.
B-04 R1	Every real-browser add and edit returned 403.	Jinja macros imported without context left the CSRF token empty; the 607 tests read the token from a meta tag, not from the form.	`with context`; new test submits each rendered form's own fields (fails 13/13 when the fix is reverted).
B-13 R1	Sign-inverted direction words outside directional findings; `value` findings bypassed V5–V7 through delta leaves; limitations carried unsupported values.	Validator checked direction only per finding kind.	D-12: delta leaves gated to matching kinds; limitations restricted to counts, dates and coverage.
B-13 R2	"You lost 1.5 kg" accepted on a weight *gain* (synonym and inflection gap); direction words with no change evidence.	Word list instead of stems; no link between words and evidence.	D-13: signed delta rendering, stem lexicon, direction words must be backed by a matching sign-bearing placeholder. R3 PASS.

Full list (30+ items, including non-blocking findings): `docs/submission/evidence-index.md` §2 and `docs/analytics/worker-notes.md` §7.

Pattern. The most valuable findings were not crashes but *false confidence*: guards that looked present, tokens that looked valid, words that looked supported. Independent, adversarial verification exposed each

of them; the Coder's own green suite did not.

10. Testing strategy

Layer	What it covers	Status
Unit	Config validation, canonical keys, URL/SSRF rules, record dates (incl. Hebrew and DD.MM.YYYY), analytics schemas, ledger, renderer, charts, policy, validator rules and boundaries.	TESTED
Integration (DB)	PK/FK/UNIQUE/CHECK, migrations and real multi-process concurrency, data preservation, user isolation, soft delete lifecycle, demo/personal exclusivity, fixture checksum and import.	TESTED
Security	ID-token, session and CSRF probes; loopback-only test login; proxy-header refusal in Demo Mode; static tests for raw connections and string-built SQL; read-only connection denies writes, PRAGMA, ATTACH, VACUUM.	TESTED
Browser	Playwright MCP by the Verifier at 1440×900 and 390×844: sign-in, tabs, add, duplicate, edit, delete, restore, permanent delete, history windows, task colours, keyboard path, mobile bar, overflow; Demo entry and reset.	TESTED (B-04, B-14). No committed E2E suite yet (B-10).
Scripted-model	Agent loop with scripted tool-call sequences, limits, errors, no-key state.	TESTED (B-15, scripted model)
Adversarial	Wrong numbers, invented evidence, causal language, undocumented-day claims, bad chart data, prompt injection in record text.	TESTED on branch at validator level (B-13); end-to-end with B-15
Golden (offline)	About 20 questions over the fixture with expected values from an independent reference calculator; pass bar 100 %.	PENDING (needs B-05 on main)
Live evaluation	Status accuracy, evidence recall, repair and degrade rates, latency, tokens.	NOT RUN (requires O-9)

11. Actual verification results

Checkpoint	Commit	Verifier rounds	Recorded result
B-01 scaffold, B-03 schema	`42c21af`	B-01 FAIL → PASS → PASS; B-03 FAIL → PASS	75 passed; ruff and mypy --strict clean.
F-01 safeguards	`42c21af`	FAIL ×5 → PASS	326 passed in 5/5 runs (R6).
B-02 sign-in	`e1f1984`	FAIL → PASS → PASS	380 passed (3 runs); 61 ID-token probes, 52 session/CSRF probes, 61 data-preservation probes incl. 6 processes × 4 threads.
B-04 data operations	`dc0cfa8`	FAIL → PASS	690 passed; Playwright both viewports; 12 same-key creates → 1 × 303 and 11 × 409.
B-14 Demo Mode	`f06e00d`	PASS	853 passed, 1 skipped (×3); real-uvicorn isolation probes (personal DB bytes unchanged, 403 for 8 proxy headers, 0 network connects without a key); Playwright both viewports.
B-13 analytics core	`ee976b4` (branch)	FAIL → FAIL → PASS	1350 passed with `PYTHONUTF8=1`; mypy strict clean (80 files); decoy-user isolation; injection strings; read-only denial with unchanged DB hash. Golden tests pending.
Clean clone, Windows, Python 3.11	`f06e00d`	Submission session (not a Verifier)	pip install, ruff and mypy --strict (58 files) clean. pytest **as cloned: 95 failed, 753 passed, 2 skipped, 4 errors** — the fixture was checked out with CRLF line endings, its SHA-256 no longer matched, and Demo Mode refused to start (W-1). With an LF checkout: 850 passed, 2 failed, 2 skipped; with `PYTHONUTF8=1`: 851 passed, 1 failed (W-2, W-3).

Windows clean-clone findings (submission session, 18 Oct)

This was the first run of the suite on Windows and on Python 3.11 recorded in the project. It found three issues that the Linux Verifier runs could not show:

ID	Finding	Root cause and proposed fix (main workstream)
W-1	**Blocking for reviewers:** on a default Git for Windows clone (`core.autocrlf=true`) Demo Mode refuses to start with "Demo fixture checksum mismatch"; 94 demo tests fail or error.	The checksum is computed over LF bytes; Git converts the JSON to CRLF on checkout. Fix: a `.gitattributes` entry such as `demo/* -text` (or `eol=lf`), then re-verify on Windows.
W-2	`test_soft_delete_migration_preserves_seeded_data` fails under the default Windows locale.	`write_text()` without `encoding="utf-8"` (also recorded by the analytics worker). Fix the test's encoding.
W-3	`test_cleanup_deletes_only_marked_working_copies` fails: creating a symlink needs a Windows privilege (WinError 1314).	Environment limitation of the test, not of the product. Skip that case on Windows when symlinks are unavailable.

Not run anywhere so far: live Google sign-in, live OpenAI calls, real Cloudflare tunnel headers, screen reader, contrast measurement, live-network SSRF. Windows PowerShell scripts (`start.ps1`, `stop.ps1`) have not been executed by any Verifier.

12. Synthetic dataset design and analytical evaluation

The demo fixture `demo/synthetic_v1.json` is generated by a seeded, reproducible script (`scripts/build_demo_fixture.py --check`) and locked by SHA-256. Dates are stored as day offsets (−29…0, tasks to +14) and shifted at import so the data always ends today. It describes one entirely fictional person.

Domain	Rows	Domain	Rows	Domain	Rows
Meals	70	Sleep	27	Steps	27
Tasks	89	Workouts	15	Articles	12
Series episodes	10	Job applications	9	Weight	8
Podcasts	8	Movies	2	About 10 % of days missing per domain; never encoded as zero	

Row counts read from the committed fixture by the submission session.

Patterns built in, and cases that must fail safely

Should be found (asserted by `tests/support/reference.py`)	Must yield partial / insufficient
• Friend meetings twice weekly in weeks 1–2, none recorded in weeks 3–4 (task days stay documented) • Interview tasks per week strictly increasing, consistent with application statuses • Workouts and family meetings about 3–4 per week • Steps higher on aerobic-workout days (positive association) • A "no clear change" control ($\|r\| < 0.3$ or flat weight) • Sleep: first 15 vs last 15 days differ above `min_delta`	• Untracked domain (mood, heart rate) • Movie trend (only 2 movies) • A specific undocumented date • Weight trend over the last week (too few points / span) • A comparison where one period lacks coverage (V7)

The reference calculator is independent of the production metric code, so golden tests compare two implementations rather than one implementation with itself. **Dataset approval:** the fixture carries `"approved_by_owner": false` until the Owner reviews all invented names (O-8).

13. Privacy, security, reproducibility and deployment

Threats and controls

Threat	Control
Prompt injection via stored text	Tools are read-only and user-scoped; `untrusted_text` is never addressable; the model cannot write digits, URLs or markup into an answer. Injection strings exist in test fixtures only.
Cross-user leakage	Every query binds `user_id` from the session; tool models forbid extra fields; decoy-user isolation tests.
SQL misuse	No model-generated SQL; static tests; read-only authorizer; 2 s budget.
Cost abuse	Per-question token budget, call and turn caps, hourly cap, one in flight; reviewer uses own key with a budget limit.
Demo exposure	Localhost-only Demo Mode, 403 for proxy/tunnel headers, refuses tunnel URLs.
Secret and PII leakage	Value-free config errors; `.gitignore` for env files, databases, documents, media, logs and traces; scan before each commit.

Repository audit (submission session, 18 Oct)

Tree and full history of 9 commits scanned (`docs/submission/security-pii-audit-report.md`). **No live credential, personal email, real record, CV, database, log or screenshot was found.** Two history-level items prevent publishing the private history as is: a company name in the first commit (removed from the files later at the Owner's request), and private session links in every commit message. The public repository will therefore be a **fresh single-commit snapshot** of a verified release (`public-release-procedure.md`); the private history is preserved unchanged.

Reproducibility and deployment

- Clean clone → venv → `pip install -e ".[dev]"` → `scripts\start.ps1 -Demo`; no credentials required.
- Fixture checksum and generator `--check` make the demo data reproducible; the working copy is rebuilt on every start or reset.
- The app is a local process; it does not need to stay hosted. After a demo the server and any tunnel are stopped and the API key is revoked.

14. Critical reflection, tradeoffs, limitations and future work

What worked

- **Independent verification paid for itself.** F-01 needed six rounds; each FAIL exposed a bypass that a self-reviewed green suite would have shipped.
- **Recorded human gates** caught a design misframing (LOG-005) before any code and kept scope changes explicit rather than drifting.
- **Moving trust from the model to the backend** — placeholders instead of numbers, fixed tools instead of SQL — made AI correctness testable with ordinary deterministic tests.
- **A frozen contract** allowed analytics to progress in parallel with the metric registry.

What we would do differently

- Test forms through their own rendered fields from the start (B-04 D-1), and verify guards by behavior, not by text (F-01).

- Run the suite on the reviewer's platform early: the Windows line-ending defect (W-1) was invisible on Linux and would have blocked the reviewer's first step.

Tradeoffs accepted

Choice	Cost
Single agent + deterministic validator (no RAG, no multi-agent)	Questions limited to what six tools can express; single-turn only.
Heuristic thresholds (V5–V9)	Not significance tests; may refuse borderline but real effects.
English lexical rules (V3, V6, V9, V10)	Best-effort; idioms and negations can slip through, although rendered numbers always show the true sign.
Server-rendered UI without JS	Simpler and CSP-friendly, but less interactive.
Parallel workstreams	Integration risk concentrated at the end; tools verified against a fake until B-05 merges.

Known limitations

- Single-user local application; offline when the process stops. A copied session cookie stays valid until its 8 h expiry.
- Demo dates shift with the anchor, so there are no weekday patterns.
- On Windows, until the line-ending fix lands, a default clone breaks the demo fixture checksum (W-1, §11); two tests depend on the locale or on symlink privileges (W-2, W-3).
- No real Google sign-in, live OpenAI, tunnel, screen-reader or contrast checks yet.

Future improvements

- Committed Playwright E2E suite in CI; accessibility audit with measured contrast.
- Opt-in live evaluation harness with labelled results and cost reporting.
- Multi-turn analyst conversations with per-turn re-validation; localization of lexical rules.
- Re-introduce AI free-text intake under the same insert-only, validated-repository guarantees.

15. Final implementation status

Final state at release. Each row cites the commit and the recorded Verifier result; anything not executed is stated as not run.

Task	State before integration (18 Oct)	Final state, commit, verification
B-01, B-03, F-01, B-02	Done	Done — `42c21af`, `e1f1984`
B-04 data operations	Done	Done — `dc0cfa8`
B-14 Demo Mode	Done	Done — `f06e00d`; fixture approval (O-8): pending the Owner's review
B-05 metric registry	In progress (main)	Done — `fcc64ba`; Verifier PASS round 1
B-07 dashboard and charts	In progress (main)	Done (functional MVP) — `32d849a`; integration Verifier FAIL (mobile table overflow) → fixed → PASS
B-13 analytics core	Verifier PASS on branch `ee976b4`; golden tests pending	Integrated — `32d849a`; real tools on real B-05 match the reference calculator; golden set not run
B-15 agent and Analyst UI	In progress (analytics)	Integrated — `32d849a`; demo-isolation fix verified (only the demo copy is opened, also after reset); live OpenAI not run
Windows fixes W-1...W-3	Found, not fixed	W-1 fixed by `.gitattributes` (in `32d849a`); W-2 and W-3 fixed in the test suite after the release. Not re-run on Windows
B-10 E2E browser suite	Pending	Not built as a committed suite; Playwright journeys were executed by the Verifiers (B-04, B-14, integration)
Integration Verifier on merged `main`	Not run	PASS (round 2) on `b6ecca8`, released as `32d849a`
Final test count	853 + 1 skipped (main); 1350 (analytics branch)	About 1,740 tests pass (full suite run several times); ruff and `mypy --strict` clean
Live OpenAI evaluation (O-9)	Not authorized, not run	Not run (requires the Owner's approval and key)
Public repository	Not created (needs Owner approval)	Sanitized snapshot prepared; publication awaits the Owner's approval
Demo video	Storyboard ready; recorded by the Owner	Recorded by the Owner from the release build

Appendix A. Decision register

ID	Decision	Approval
ADR-001	Stack, data and auth architecture (A-02, A-03, A-04)	Owner, 16 Oct 2026
ADR-002	Job and trend agents with Run now (A-04)	Approved 16 Oct; deferred by ADR-005
ADR-003	Quick tunnel and demo security S1–S12	Owner, 16 Oct 2026
ADR-004	Data preservation and deletion policy	Owner directive, 17 Oct 2026

ADR-005	Personal analytics, runtime agent, Evidence Validation, Demo Mode	Scope 17 Oct; design approved 18 Oct (LOG-017); amended LOG-019

Sources: `DEVELOPMENT_LOG.md` (LOG-002…LOG-020, decision register), `PROJECT_PLAN.md`, `docs/architecture/`, `docs/analytics/worker-notes.md` on `feature/analytics-agent`, `docs/submission/evidence-index.md`, `docs/submission/security-pii-audit-report.md`.